



Indian Institute of Information Technology Guwahati

Department of Computer Science and Engineering

Fast Authentication Between UAVs

A PUF-Based Four-Phase Swarm Authentication Protocol:
Design and Provable Security

Author: Md Ziyad Hussain

Roll No.: 2301128

Email: ziyad.hussain23b@iiitg.ac.in

Supervisor: Dr. Rakesh Matam
Assistant Professor, CSE

Indian Institute of Information Technology Guwahati

Bongora, Assam 781015, India

2026

Abstract

Unmanned Aerial Vehicle (UAV) swarms require authentication that is fast, lightweight, and resilient to the physical capture of individual drones. Traditional public-key infrastructure (RSA-2048, ECC-256) adds millisecond-scale handshake cost on embedded processors and, more seriously, relies on private keys stored in non-volatile memory—a liability the moment a UAV is captured. We present a four-phase authentication protocol whose root of trust is a Physical Unclonable Function (PUF) embedded in each UAV. The protocol covers (1) secure enrollment, in which a fuzzy extractor over a BCH(255,131,18) code turns noisy PUF measurements into a *stable* per-device master key while storing no secret on the drone; (2) UAV–Ground Station (GS) mutual authentication in which every message is protected by a keyed message-authentication code and the raw PUF response never leaves the device; (3) direct UAV–UAV peer authentication, without GS involvement, rooted in *per-pair* credentials delivered under authenticated encryption; and (4) session-key establishment in which a mandatory, authenticated ephemeral Diffie–Hellman exchange provides perfect forward secrecy. The protocol uses only a 160-bit hash—instantiable as SHA3-256 truncated to 160 bits or SPONGENT-160—together with a keyed MAC, a lightweight authenticated-encryption scheme, a key-derivation function, and a single elliptic curve, so that it fits comfortably on resource-constrained aerial platforms. We give a complete security analysis: six theorems covering mutual authentication in both directions, peer authentication, replay and man-in-the-middle resistance, physical-capture resistance, session-key secrecy, and perfect forward secrecy, each reduced to standard assumptions and mirrored by a symbolic model in the Tamarin prover.

Keywords: UAV authentication, Physical Unclonable Function, PUF, SPONGENT, SHA3, swarm security, lightweight cryptography, peer-to-peer authentication, fuzzy extractor, BCH code, forward secrecy.

Contents

1	Introduction	4
1.1	Background and Motivation	4
1.2	Limitations of Traditional Authentication	4
1.3	Physical Unclonable Functions as a Solution	4
1.4	Contributions of This Paper	4
2	Background and Existing Technologies	5
2.1	UAV Communication Architecture	5
2.2	Physical Unclonable Functions (PUFs)	5
2.2.1	PUF Fundamentals	5
2.2.2	Types of PUFs	5
2.2.3	PUF Noise and Reliability	5
2.3	Lightweight Cryptographic Hash Functions	5
2.3.1	SHA3-256 (Keccak)	5
2.3.2	SPONGENT-160	5
2.4	Fuzzy Extractors and BCH Error Correction	5
2.4.1	Fuzzy Extractors	5
2.4.2	BCH Code Parameters	6
3	Related Work	6
3.1	PUF-Based Authentication for IoT and UAVs	6
3.2	Peer-to-Peer UAV Authentication	6
3.3	Lightweight Hash Functions for Constrained Devices	6
3.4	Comparison of Existing Approaches	6
4	Proposed Protocol Design	7
4.1	Threat Model and Design Goals	7
4.1.1	Threat Model	7
4.1.2	Design Goals	7
4.2	System Model and Notation	7
4.3	Phase 1: Secure Enrollment and Registration	8
4.4	Phase 2: UAV–Ground Station Mutual Authentication	9
4.5	Phase 3: UAV-to-UAV Peer Authentication	11
4.6	Phase 4: Session Key Establishment and Forward Secrecy	12
5	Security Analysis	12
5.1	Assumptions	12
5.2	Phase 2: Mutual Authentication	13
5.3	Replay Attack Resistance	13
5.4	Phase 3: Peer Mutual Authentication	13
5.5	Man-in-the-Middle Resistance	14
5.6	Session-Key Secrecy and Forward Secrecy	14
5.7	Physical Capture Resistance	14
5.8	Symbolic Verification	14
5.9	Summary of Security Properties	15

6	Discussion	15
6.1	Scalability	15
6.2	Design Choices	15
6.3	Noise Tolerance	15
6.4	Limitations and Future Work	16
7	Conclusion	16

1 Introduction

1.1 Background and Motivation

Unmanned Aerial Vehicles (UAVs) have become integral to modern defense, disaster response, precision agriculture, environmental monitoring, and public safety. Multi-UAV *swarms*—ten or more drones cooperating to surveil a stadium, patrol a border, or search a disaster zone—are now the standard operational unit [1]. Such swarms communicate continuously with a Ground Station (GS) over a command-and-control link and with one another over peer links to maintain formation, fuse sensor data, and route around outages.

A fundamental prerequisite for any of this is *mutual authentication*: each UAV must verify the identity of its GS and of every peer before accepting commands, sharing telemetry, or relaying messages. Without it, an adversary can inject a rogue drone into the swarm, intercept sensitive data, issue unauthorized flight commands, or mount man-in-the-middle attacks on inter-UAV channels [9].

1.2 Limitations of Traditional Authentication

Conventional options fit the UAV-swarm regime poorly. **RSA-2048 PKI** requires several milliseconds per signature verification on embedded processors and attaches hundreds of bytes of certificate per handshake [2]. **ECC-256** halves the cost but still keeps a private key in non-volatile memory (NVM) that a captured drone can surrender through side-channel or cold-boot attacks [3]. **Pre-shared keys** reach sub-millisecond latency but compromise the entire swarm if any single device is captured, and require $O(N^2)$ pairwise keys [8]. **Blockchain-based** schemes incur seconds of consensus latency, incompatible with real-time coordination [4]. In every case the weakness is the same: a long-term secret *stored* on a device that may fall into an adversary’s hands.

1.3 Physical Unclonable Functions as a Solution

A Physical Unclonable Function (PUF) is a hardware primitive that maps challenges to responses using intrinsic, sub-nanometer manufacturing variations unique to one integrated circuit [10]. A PUF is *unclonable* (it cannot be replicated, even by its manufacturer), *unpredictable* (responses to unseen challenges are unrelated to prior ones), *tamper-evident* (invasive probing destroys the response), and *lightweight* (an Arbiter PUF needs roughly 1,200 gate equivalents). Crucially, *no key is stored*: the “key” is the silicon itself. This removes the dominant attack surface of PKI and PSK schemes and is the foundation of our design.

1.4 Contributions of This Paper

We present a complete four-phase PUF-based authentication framework for UAV swarms. Its contributions are:

1. **A stable PUF-derived key with no stored secret.** Enrollment distills a stable per-device master key from the PUF via a fuzzy extractor; the drone regenerates it on demand from its PUF and *public* helper data, so no secret ever resides in NVM.
2. **Keyed authentication that keeps the PUF response on-device.** Every handshake message is authenticated with a keyed MAC under a PUF-derived key, and the raw PUF response is never transmitted, so it cannot be observed or harvested over the air.
3. **GS-free peer authentication with per-pair trust.** Peers authenticate directly using *per-pair* credentials delivered under authenticated encryption during Phase 2, so a compromised drone endangers only its own links.
4. **Mandatory forward secrecy.** An authenticated ephemeral Diffie–Hellman exchange is folded into every session key, so a later compromise of long-term material cannot unlock past sessions.
5. **A complete security analysis.** Six theorems, each reduced to standard cryptographic assumptions and corroborated by a mechanised Tamarin symbolic model, establish the protocol’s authentication, secrecy, and capture-resistance guarantees.

The remainder of the paper covers background (§2), related work (§3), the protocol design (§4), the security analysis (§5), a discussion of scalability and design choices (§6), and the conclusion (§7).

2 Background and Existing Technologies

2.1 UAV Communication Architecture

A UAV swarm has two communication planes. The *vertical* plane connects each UAV to the GS for commands, telemetry, and mission updates; the *horizontal* plane connects UAVs to one another for formation control and data relay. Authentication must secure both, and it must continue to work on the horizontal plane even when the GS link is briefly unavailable. Our design therefore treats UAV–GS and UAV–UAV authentication as distinct phases with distinct trust roots.

2.2 Physical Unclonable Functions (PUFs)

2.2.1 PUF Fundamentals

A PUF implements a challenge–response mapping $R = \text{PUF}(C)$ that is determined by uncontrollable fabrication variations. Two nominally identical chips produce statistically independent responses to the same challenge (inter-chip Hamming distance near 50%), while a single chip reproduces its own response with only small deviation (intra-chip Hamming distance of a few percent). These two properties—uniqueness and reliability—make a PUF a per-device fingerprint that no attacker can duplicate.

2.2.2 Types of PUFs

Common strong PUFs include the *Arbiter PUF*, which races two symmetric delay paths and outputs a bit according to which signal arrives first, and the *Ring-Oscillator PUF*, which compares oscillator frequencies. Strong PUFs expose an exponentially large challenge space, which is what allows a PUF to serve as a source of many independent secrets. We assume a strong PUF with a 128-bit challenge space throughout.

2.2.3 PUF Noise and Reliability

Because a PUF measures physical quantities, its response drifts with temperature, supply voltage, and aging, producing a bit-error rate (BER) of typically 3–10% between evaluations of the same challenge. A raw response therefore cannot be used directly as a key; it must first be reconciled to a stable value. This is the role of the fuzzy extractor (§2.4).

2.3 Lightweight Cryptographic Hash Functions

2.3.1 SHA3-256 (Keccak)

SHA3-256 is the NIST-standard sponge hash [16, 17]. Truncated to 160 bits it offers 80-bit collision resistance and benefits from fast, widely available software implementations, making it our software-oriented instantiation of the abstract hash $h(\cdot)$.

2.3.2 SPONGENT-160

SPONGENT-160 is a lightweight sponge hash designed for hardware, occupying only a few thousand gate equivalents [15]. It shares the 160-bit interface of truncated SHA3, so the protocol can switch between the two without any structural change; SPONGENT is our hardware-oriented instantiation.

2.4 Fuzzy Extractors and BCH Error Correction

2.4.1 Fuzzy Extractors

A fuzzy extractor turns a noisy PUF response into a reproducible key using public *helper data* [5]. It is a pair of algorithms (Gen, Rep). Given an enrollment response R , Gen produces helper data P and a key; given a later noisy response R' and the same P , Rep recovers the identical key whenever R' is close enough to R . We use the standard *code-offset* construction over a linear code C : enrollment picks a random codeword c and publishes the offset $s = R \oplus c$; reproduction computes $c' = R' \oplus s$ and decodes it back to c , so that if the Hamming distance $d_H(R, R') \leq t$ the original response R is recovered exactly.

An important and often-misstated point concerns how much the public helper data reveals. The offset s does *not* perfectly hide R ; it discloses a bounded amount of information—at most the code’s redundancy, $n - k$ bits. The correct security statement is therefore about *residual min-entropy*: if

R has min-entropy m , then R retains at least $m - (n - k)$ bits of min-entropy given P . A strong extractor applied to R then yields a key that is statistically close to uniform, provided the residual entropy comfortably exceeds the key length. We make this precise in Lemma 1 and use it to size the enrollment in Phase 1.

2.4.2 BCH Code Parameters

We instantiate the code with BCH(255,131,18) over $\text{GF}(2^8)$:

- **Codeword length** $n = 255$ bits;
- **Message length** $k = 131$ bits;
- **Error-correction capability** $t = 18$ bit-flips;
- **Minimum distance** $d = 37$;
- **Redundancy** $n - k = 124$ parity bits.

At a 3% error rate a 128-bit response is expected to flip $128 \times 0.03 \approx 3.84$ bits, well within the $t = 18$ correction radius, so reproduction succeeds with overwhelming probability. Decoding uses the standard pipeline of syndrome computation, the Berlekamp–Massey algorithm to find the error-locator polynomial, a Chien search to locate errors, and bit-flipping to correct them [6].

3 Related Work

3.1 PUF-Based Authentication for IoT and UAVs

Early PUF authentication schemes target a single device authenticating to a server [2, 8, 13]. They establish the PUF-plus-fuzzy-extractor pattern but do not address the peer-to-peer coordination that a swarm needs.

3.2 Peer-to-Peer UAV Authentication

Peer authentication among UAVs has been studied with symmetric credentials [3] and in cross-domain settings [9, 12]. A recurring weakness is that peer trust is rooted in a single shared secret, so one captured node endangers the whole mesh. Our design instead roots peer trust in *per-pair* credentials, confining the blast radius of a capture.

3.3 Lightweight Hash Functions for Constrained Devices

SPONGENT [15] and related lightweight primitives [14] target minimal hardware area. We keep a hash-agnostic interface so that a device may run SHA3 in software or SPONGENT in hardware without changing the protocol.

3.4 Comparison of Existing Approaches

Table 1 contrasts our design with representative alternatives along the security features that matter for a swarm.

Table 1: Feature Comparison of UAV/IoT Authentication Approaches

Approach	PUF	Peer auth	No stored key	Fwd sec	Err corr	Formal proof
RSA-2048 PKI	No	Yes	No	Opt.	N/A	Partial
ECC-256	No	Yes	No	Opt.	N/A	Partial
PSK (AES-GCM)	No	Yes	No	No	N/A	Partial
Gope [2]	Yes	No	Yes	No	Simple	Informal
Li [9]	Yes	Partial	Yes	No	BCH	Informal
Khan [12]	Yes	No	Yes	Yes	BCH	Informal
Bera [3]	No	Yes	No	No	N/A	Informal
This work	Yes	Yes	Yes	Yes	BCH	Games + symbolic

Our protocol is the only entry that simultaneously provides a PUF root of trust, direct peer-to-peer authentication, no stored key on the device, mandatory forward secrecy, BCH-based error

correction, and a security argument combining game-based reductions with a mechanised symbolic model.

4 Proposed Protocol Design

This section presents the four-phase protocol in full. We begin with the threat model and design goals, fix the notation, and then specify each phase message by message, with the mathematics of every step accompanied by a plain explanation of what it does and why it is secure.

4.1 Threat Model and Design Goals

4.1.1 Threat Model

We consider a Dolev–Yao adversary [18] augmented with physical capabilities: (1) **Network adversary**—may eavesdrop, intercept, modify, replay, delay, or drop any wireless message; (2) **Active challenger**—may pose as the GS toward an honest UAV and send adversarially chosen challenges and nonces; (3) **Physical capture**—may seize UAVs and read their NVM, but cannot clone PUF hardware, since invasive probing destroys it; (4) **Computational bounds**—a probabilistic polynomial-time (PPT) adversary cannot invert the hash, forge a MAC or authenticated ciphertext, break PUF unclonability, or solve the computational Diffie–Hellman problem, except with negligible probability; (5) **Side channels**—standard countermeasures (constant-time primitives, power-analysis resistance) are assumed.

4.1.2 Design Goals

The protocol targets: (1) mutual authentication in both directions, verified by keyed MACs; (2) anonymity via rotating temporary identities; (3) replay and man-in-the-middle resistance through nonces, timestamps, and transcript binding; (4) *no stored secret* on the UAV, since the master key is regenerated from the PUF on demand; (5) GS-free peer authentication rooted in per-pair credentials; (6) perfect forward secrecy through a mandatory ephemeral key exchange; (7) lightweight operation (only a hash, keyed MAC, AEAD, KDF, and one elliptic curve); (8) scalability, since the $O(N^2)$ peer authentications are independent and parallelizable; and (9) noise tolerance through the BCH fuzzy extractor.

4.2 System Model and Notation

The system consists of one GS with ample computation and tamper-resistant storage, and N UAVs, each carrying a PUF, a lightweight processor, a radio, and a small non-volatile memory. Table 2 lists the notation used throughout.

Table 2: Protocol Notation

Symbol	Description
UAV_i	The i -th Unmanned Aerial Vehicle
GS	Ground Station (enrollment and credential authority)
ID_i	Permanent identity of UAV_i (64-bit)
TID_i	Rotating temporary identity for anonymity
PUF_i	Physical Unclonable Function of UAV_i
$\mathbf{C}_i$	Enrollment challenge block $(C_i^{(1)}, \dots, C_i^{(L)})$
R, R'	Enrollment response; noisy field response
$\text{FE} = (\text{Gen}, \text{Rep})$	Fuzzy extractor (§2.4)
$P_i = (s_i, \text{seed}_i)$	<i>Public</i> helper data for UAV_i
mk_i	Stable per-device master key (never stored on the UAV)
mk_{GS}	GS-only master key for pairwise credentials
Cred_{ij}	Per-pair credential shared by $\text{UAV}_i, \text{UAV}_j$
K_{auth}^i	UAV–GS MAC key, $= \text{KDF}(\text{mk}_i; \text{p2-auth})$
K_{auth}^{ij}	Peer MAC key, $= \text{KDF}(\text{Cred}_{ij}; \text{peer-auth})$
$\text{SK}_i, \text{SK}_{ij}$	Session keys (Phase 2 / Phase 3)
$h(\cdot)$	160-bit hash: SHA3-256 ₁₆₀ or SPONGENT-160
$\text{MAC}_K(\cdot)$	Keyed message-authentication code
$\text{AE.Enc}, \text{AE.Dec}$	Authenticated encryption (AEAD)
$\text{KDF}(\cdot; \ell)$	Key-derivation function with label ℓ
g, g^a, g^{ab}	Generator; ephemeral public share; DH secret
N_x, n_x	Random nonces (128-bit)
T_x	Timestamp (32-bit)
$\oplus, \parallel$	Bitwise XOR; concatenation

Figure 1 shows how the four phases fit together: a one-time secure enrollment, an in-field UAV–GS handshake that also distributes peer credentials, GS-free peer handshakes, and the session keys that result.

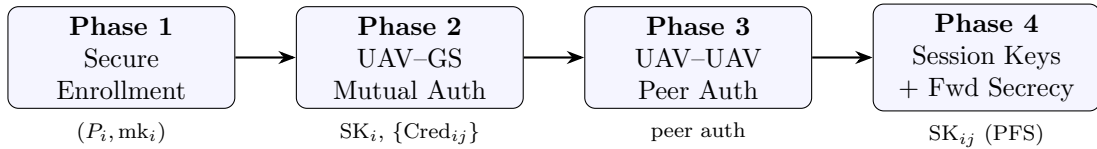


Figure 1: The four phases and what each produces. Enrollment is performed once, in a secure facility; Phases 2–4 run in the field.

4.3 Phase 1: Secure Enrollment and Registration

Enrollment runs once per UAV, in a physically secure facility over a trusted channel (a wired link or a shielded RF cage), before the drone is deployed. Its purpose is to establish the stable master key mk_i and the public helper data P_i , so that in the field the UAV can regenerate mk_i from its own PUF without ever storing a secret.

Step 1.1: PUF interrogation. The GS draws a block of L random 128-bit challenges $\mathbf{C}_i = (C_i^{(1)}, \dots, C_i^{(L)})$ and has the UAV evaluate its PUF on each:

$$R = (\text{PUF}_i(C_i^{(1)}), \dots, \text{PUF}_i(C_i^{(L)})). \quad (1)$$

Concatenating L blocks aggregates enough physical entropy to survive the helper-data loss quantified below; R is the raw enrollment response.

Step 1.2: Key and helper-data generation. The GS runs the fuzzy-extractor generator Gen on R . It samples a random seed, forms a code-offset sketch, and extracts the master key:

$$c = \text{C.Encode}(r), \quad r \xleftarrow{\$} \{0, 1\}^k, \quad s = R \oplus c, \quad (2)$$

$$\text{mk}_i = \text{KDF}(\text{Ext}_{\text{seed}}(R); \text{root}), \quad P_i = (s, \text{seed}). \quad (3)$$

Here s is the public sketch that will later let a noisy response be decoded back to R , and Ext is a strong extractor (realised by the KDF) that compresses R into a near-uniform key. The pair (P_i, mk_i) is the output of Gen .

Step 1.3: Sizing the enrollment. Because the sketch s leaks at most $n - k = 124$ bits about each block (Lemma 1), the number of blocks L is chosen so that the entropy left after the leak still exceeds the desired key length ℓ :

$$\sum_{b=1}^L (m_b - (n - k)) \geq \ell + 2 \log(1/\varepsilon), \quad (4)$$

where m_b is the measured per-block min-entropy and ε is a negligible statistical-distance target. This inequality is what guarantees mk_i is a strong key rather than a slightly-random one.

Step 1.4: Identity and pairwise-credential setup. The GS assigns a permanent identity and an initial rotating temporary identity, and fixes a GS-only master key from which all per-pair credentials are derived:

$$\text{TID}_i = h(\text{ID}_i \parallel \text{seed}'_i), \quad \text{Cred}_{ij} = \text{KDF}(\text{mk}_{\text{GS}}; \text{pair-cred} \parallel \min(i, j) \parallel \max(i, j)). \quad (5)$$

The temporary identity hides the permanent one from eavesdroppers, and each Cred_{ij} is a distinct secret for exactly one pair. These credentials are *not* released here; they are delivered, encrypted, during Phase 2.

Step 1.5: Storage. After enrollment:

- **GS stores** $\{\text{ID}_i, \text{TID}_i, \text{C}_i, P_i, \text{mk}_i\}$ per UAV, plus the single master key mk_{GS} , all in tamper-resistant memory.
- **UAV_i stores** $\{\text{TID}_i, \text{C}_i, P_i\}$ only. Every one of these is public; *no secret is stored on the drone*. This is the central advantage of the design: capturing a UAV yields no key material, because the master key exists only transiently, regenerated from the PUF whenever it is needed.

4.4 Phase 2: UAV–Ground Station Mutual Authentication

Phase 2 runs when a UAV powers up in the field. It is a four-message exchange that mutually authenticates the UAV and GS, establishes a forward-secret session key SK_i , and delivers the UAV's per-pair credentials for Phase 3. Both sides key their MACs with $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{p2-auth})$: the GS computes it from the stored mk_i , and the UAV regenerates mk_i from its PUF. Figure 2 shows the message flow.

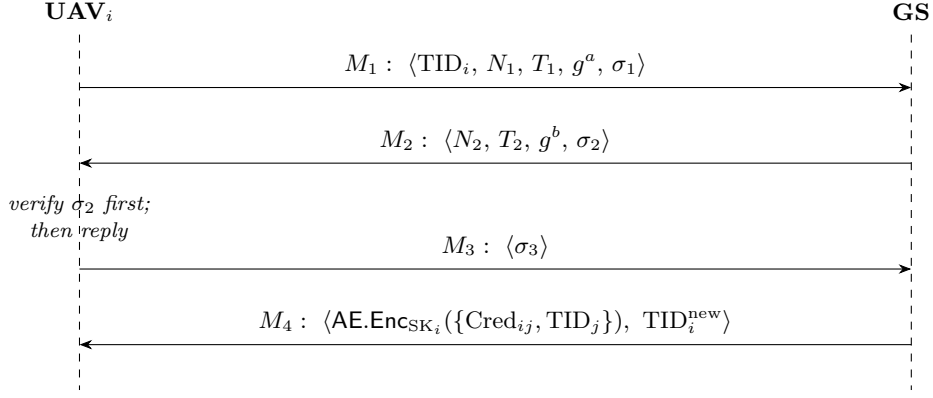


Figure 2: Phase 2 message sequence. The UAV validates the GS’s MAC before it replies, so a fraudulent challenger receives no response; peer credentials are delivered under authenticated encryption only after mutual authentication succeeds.

Message 1 (Authentication request): $\text{UAV}_i \rightarrow \text{GS}$. The UAV picks a fresh nonce and an ephemeral Diffie–Hellman scalar, and authenticates the opening message:

$$N_1 \xleftarrow{\$} \{0, 1\}^{128}, \quad a \xleftarrow{\$} \text{scalar}, \quad (6)$$

$$\sigma_1 = \text{MAC}_{K_{\text{auth}}^i}(\text{M1} \parallel \text{TID}_i \parallel N_1 \parallel T_1 \parallel g^a), \quad (7)$$

$$M_1 = \langle \text{TID}_i, N_1, T_1, g^a, \sigma_1 \rangle. \quad (8)$$

Because σ_1 is a MAC keyed by K_{auth}^i , only a party that holds mk_i —that is, the genuine UAV (through its PUF) or the GS (through its database)—can produce it. The tag M1 marks the message type so that a message from one step can never be replayed as another.

Message 2 (GS response): $\text{GS} \rightarrow \text{UAV}_i$. The GS checks the timestamp and the nonce for freshness, looks up mk_i , verifies σ_1 , and answers with its own nonce and ephemeral share:

$$N_2 \xleftarrow{\$} \{0, 1\}^{128}, \quad b \xleftarrow{\$} \text{scalar}, \quad (9)$$

$$\sigma_2 = \text{MAC}_{K_{\text{auth}}^i}(\text{M2} \parallel \text{TID}_i \parallel N_1 \parallel N_2 \parallel T_2 \parallel g^a \parallel g^b), \quad (10)$$

$$M_2 = \langle N_2, T_2, g^b, \sigma_2 \rangle. \quad (11)$$

The tag σ_2 authenticates the GS to the UAV: it binds both nonces and both ephemeral shares under the shared key, so no network adversary can forge or alter it.

Message 3 (UAV confirmation): $\text{UAV}_i \rightarrow \text{GS}$. The UAV first regenerates its master key from its PUF and *verifies σ_2 before doing anything else*:

$$\text{mk}_i = \text{Rep}(\text{PUF}_i(C_i), P_i), \quad (12)$$

$$\text{abort silently if } \sigma_2 \text{ is invalid.} \quad (13)$$

This “verify-before-respond” rule is what prevents a fraudulent GS from using the UAV as an oracle: an attacker who cannot forge σ_2 elicits no reply at all. If the check passes, the UAV confirms the transcript:

$$\sigma_3 = \text{MAC}_{K_{\text{auth}}^i}(\text{M3} \parallel \mathcal{T}), \quad M_3 = \langle \sigma_3 \rangle, \quad (14)$$

where the transcript $\mathcal{T}$ is the concatenation of all fields of M_1 and M_2 . Note that the raw PUF response is consumed inside Rep and *never appears on the wire*; only a MAC over public values is

sent.

Message 4 (Confirmation and credential delivery): $\text{GS} \rightarrow \text{UAV}_i$. After verifying σ_3 , both parties hold the same ingredients, so each computes the forward-secret session key

$$\text{SK}_i = \text{KDF}(\text{mk}_i \parallel g^{ab} \parallel \mathcal{T}; \text{p2-sess}), \quad (15)$$

and the GS delivers the UAV's per-pair credentials and a fresh identity under authenticated encryption keyed by SK_i :

$$\text{CredPkg} = \text{AE.Enc}_{\text{SK}_i}(\eta; \text{TID}_i; \{(\text{Cred}_{ij}, \text{TID}_j)\}_{j \neq i}), \quad (16)$$

$$\text{TID}_i^{\text{new}} = h(\text{TID}_i \parallel \text{mk}_i \parallel N_1 \parallel N_2), \quad M_4 = \langle \text{CredPkg}, \text{TID}_i^{\text{new}} \rangle. \quad (17)$$

Authenticated encryption gives the credentials both confidentiality and integrity: an eavesdropper learns nothing about any Cred_{ij} , and a tampered package is rejected. The session key mixes in the Diffie–Hellman secret g^{ab} , which is what makes it forward-secret (Phase 4). After Phase 2 the UAV holds SK_i , its peer credentials $\{\text{Cred}_{ij}\}$, and a rotated identity.

4.5 Phase 3: UAV-to-UAV Peer Authentication

Phase 3 lets any two UAVs authenticate each other directly, using the per-pair credential Cred_{ij} that each received (encrypted) in Phase 2. It needs no GS involvement, so it works even when the GS link is down. Both sides key their MACs with $K_{\text{auth}}^{ij} = \text{KDF}(\text{Cred}_{ij}; \text{peer-auth})$. Figure 3 shows the three-message flow.

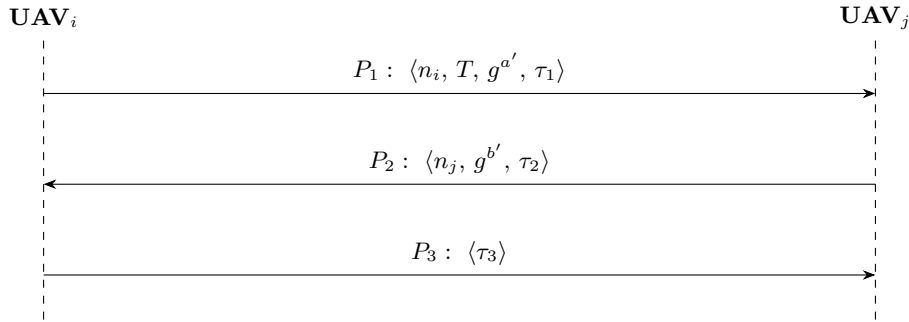


Figure 3: Phase 3 message sequence. Every token is a MAC keyed by the per-pair credential Cred_{ij} and tagged with its message type, so tokens cannot be reflected or reused across steps.

Message P1 (Peer request): $\text{UAV}_i \rightarrow \text{UAV}_j$. The initiator picks a fresh nonce and ephemeral share and sends an authenticated request:

$$n_i \xleftarrow{\$} \{0, 1\}^{128}, \quad a' \xleftarrow{\$} \text{scalar}, \quad (18)$$

$$\tau_1 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{P1} \parallel i \parallel j \parallel n_i \parallel T \parallel g^{a'}), \quad P_1 = \langle n_i, T, g^{a'}, \tau_1 \rangle. \quad (19)$$

Because τ_1 is keyed by Cred_{ij} , which only UAV_i and UAV_j possess, a third party—even one holding some other pair's credential—cannot produce it.

Message P2 (Peer response): $\text{UAV}_j \rightarrow \text{UAV}_i$. The responder verifies τ_1 , then answers with its own nonce and share:

$$\tau_2 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{P2} \parallel i \parallel j \parallel n_i \parallel n_j \parallel g^{a'} \parallel g^{b'}), \quad P_2 = \langle n_j, g^{b'}, \tau_2 \rangle. \quad (20)$$

τ_2 binds both identities and both nonces, so it authenticates UAV_j to UAV_i and confirms that both are in the same fresh session.

Message P3 (Completion): $\text{UAV}_i \rightarrow \text{UAV}_j$. The initiator verifies τ_2 and closes the hand-

shake with a final tag over the transcript $\mathcal{T} = P_1 \| P_2$:

$$\tau_3 = \text{MAC}_{K_{\text{auth}}^{ij}}(P_3 \| \mathcal{T}), \quad P_3 = \langle \tau_3 \rangle. \quad (21)$$

The three distinct type tags (P_1, P_2, P_3) ensure a token from one step can never be replayed as another, which rules out reflection attacks. For a swarm of N UAVs, full-mesh peer authentication runs $N(N-1)/2$ independent Phase 3 exchanges (for example, 45 for $N = 10$), all of which may proceed in parallel.

4.6 Phase 4: Session Key Establishment and Forward Secrecy

Phase 4 is the keying that both interactive phases finish with. In Phase 2 the UAV–GS key is SK_i of Eq. (15); in Phase 3 the peer key is

$$\text{SK}_{ij} = \text{KDF}(\text{Cred}_{ij} \| g^{a'b'} \| \mathcal{T}; \text{peer-sess}). \quad (22)$$

Both keys have the same shape, which we write uniformly as

$$\text{SK} = \text{KDF}\left(\underbrace{k_{\text{lt}}}_{\text{mk}_i \text{ or } \text{Cred}_{ij}} \| g^{xy} \| \mathcal{T}; \ell\right). \quad (23)$$

Two independent secrets go into every session key. The first is the long-term key k_{lt} , which ties the session to the PUF (via mk_i) or to the pair (via Cred_{ij}). The second is the ephemeral Diffie–Hellman secret g^{xy} , whose public shares were authenticated inside the MAC transcript of the corresponding handshake. Mixing in g^{xy} is what provides *perfect forward secrecy*: once the ephemeral scalars are erased, an adversary who later learns k_{lt} still cannot reconstruct a past key, because doing so would require solving Diffie–Hellman on the recorded shares. The exchange is mandatory—there is no derivation path that omits g^{xy} —so a session either establishes a forward-secret key or fails.

5 Security Analysis

We now analyse the protocol formally. Each theorem is proved by reducing an attack to the violation of a standard assumption; the reductions are then mirrored by a symbolic model (§5.8).

5.1 Assumptions

The proofs rely on the following standard assumptions.

1. **Hash security.** h is pre-image, second-pre-image, and collision resistant; in the reductions it is modelled as a random oracle.
2. **MAC unforgeability.** MAC is existentially unforgeable under chosen-message attack (EUF-CMA): without the key, a fresh valid tag can be produced only with negligible probability.
3. **AEAD security.** AE provides ciphertext indistinguishability (IND-CCA) and ciphertext integrity (INT-CTXT).
4. **PUF unpredictability.** Given polynomially many challenge–response pairs, the response to a fresh challenge is computationally indistinguishable from uniform to an adversary that does not possess the device; invasive probing destroys the PUF.
5. **Diffie–Hellman.** The gap computational Diffie–Hellman (gap-CDH) problem is hard in $\mathbb{G}$.

We first record the helper-data property that underpins the strength of the master key.

Lemma 1 (Helper-data privacy). *Let the enrollment response R have conditional min-entropy $\tilde{H}_\infty(R) = m$. The code-offset sketch $s = R \oplus c$ discloses at most $n - k$ bits, so*

$$\tilde{H}_\infty(R | P) \geq m - (n - k). \quad (24)$$

Consequently, if the extractor output length ℓ satisfies $\ell \leq m - (n - k) - 2 \log(1/\varepsilon)$, then mk is within statistical distance ε of uniform given the public helper data P .

Proof. Given the internal randomness r , the sketch $s = R \oplus c$ is a deterministic function of R that pins R to a coset of the $[n, k]$ code $\mathbf{C}$; revealing that coset fixes at most $n - k$ syndrome bits, so by the chain rule for average min-entropy $\tilde{H}_\infty(R \mid s) \geq \tilde{H}_\infty(R) - (n - k)$, and the seed is independent of R . Applying the strong-extractor property to the residual source gives a key within distance ε of uniform. $\square$ $\square$

5.2 Phase 2: Mutual Authentication

Theorem 2 (Phase 2 mutual authentication). *After a successful Phase 2 exchange, UAV_i and the GS have mutually authenticated one another, and both agree on the transcript $\mathcal{T}$, except with negligible probability.*

Proof. Both directions rest on the MAC key $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{p2-auth})$, which by Lemma 1 and PUF unpredictability is unknown to any adversary lacking either the PUF or the GS database. (*GS authenticates UAV.*) The GS accepts only if σ_1 (and later σ_3) verifies under K_{auth}^i ; producing a fresh valid tag without the key is exactly an EUF-CMA forgery. (*UAV authenticates GS.*) Symmetrically, the UAV accepts only if σ_2 verifies; although every field inside σ_2 is public, the *key* is secret, so a fresh valid σ_2 is again a forgery. A nonce collision that could enable transcript reuse occurs with probability at most $q^2/2^{128}$ for q sessions. Absent forgery and collision, the two accepting parties share identical fields in M_1 and M_2 , i.e. they agree on $\mathcal{T}$. $\square$ $\square$

Corollary 3 (No PUF read-out oracle). *An adversary that impersonates the GS learns no PUF response, so it cannot harvest challenge–response pairs to model the PUF.*

Proof. By the verify-before-respond rule, the UAV emits M_3 only after σ_2 verifies, which by Theorem 2 an adversary can force only by forging a MAC. When the check fails the UAV sends nothing; when it passes, the only value on the wire is σ_3 , a MAC over public transcript fields—the PUF response is consumed inside Rep and is never transmitted. Hence no challenge–response pair is exposed. $\square$ $\square$

5.3 Replay Attack Resistance

Theorem 4 (Replay resistance). *Phase 2 and Phase 3 resist replay attacks.*

Proof. Three mechanisms combine. First, every message carries a fresh 128-bit nonce and a timestamp verified within a window ΔT ; a verbatim replay reuses a stale nonce or timestamp and is rejected. Second, each MAC binds a per-message type tag ($\text{M1}, \dots, \text{P3}$), so a token from one step cannot be accepted at another. Third, from the second message onward each MAC binds the partner’s nonce, so a token from one session cannot be reused in another without producing a mismatch—which, by Theorems 2 and 5, would require a forgery. $\square$ $\square$

5.4 Phase 3: Peer Mutual Authentication

Theorem 5 (Peer mutual authentication). *After a successful Phase 3 exchange, UAV_i and UAV_j have mutually authenticated one another, without GS involvement, and no per-pair secret is exposed in transit.*

Proof. The credential Cred_{ij} reaches each endpoint only inside the Phase 2 package $\text{AE.Enc}_{\text{SK}_i}(\dots)$; by INT-CTXT the adversary cannot make a UAV accept a substituted credential, and by IND-CCA it learns nothing about Cred_{ij} . Given a secret Cred_{ij} , the tokens τ_1, τ_2, τ_3 are MACs under K_{auth}^{ij} ; each binds both identities and both nonces, so a fresh acceptance forces a matching computation by the partner—otherwise an EUF-CMA forgery. Because credentials are pair-specific, a third party holding some other $\text{Cred}_{k\ell}$ has no information about Cred_{ij} and cannot assert identity i to j . $\square$ $\square$

5.5 Man-in-the-Middle Resistance

Theorem 6 (MITM resistance). *The protocol resists active man-in-the-middle attacks in both Phase 2 and Phase 3.*

Proof. Every accepted message is a MAC (or an authenticated ciphertext) over a transcript that includes fresh nonces, a timestamp, a type tag, and—from the second message onward—the partner’s nonce and ephemeral share. Altering any field invalidates the covering tag, and forging a new tag requires the secret key (EUF-CMA / INT-CTXT). By the agreement guarantees of Theorems 2 and 5, both endpoints therefore hold the identical transcript, so an interposed adversary cannot sit undetected between them. $\square$ $\square$

5.6 Session-Key Secrecy and Forward Secrecy

Theorem 7 (Session-key secrecy). *For an adversary that corrupts neither endpoint of the target session, the session key of Eq. (23) is indistinguishable from uniform.*

Proof. The key is $\text{KDF}(k_{\text{lt}} \| g^{xy} \| \mathcal{T})$. Two independent secrets protect it: the long-term key k_{lt} (mk_i by Lemma 1 and PUF unpredictability, or Cred_{ij} by IND-CCA of its delivery, Theorem 5) and the Diffie–Hellman secret g^{xy} . Modelling the KDF as a pseudorandom function, replacing it by a random function is undetectable up to its PRF advantage; the input g^{xy} is unpredictable under gap-CDH given only the authenticated shares g^x, g^y . Hence the output is uniform up to negligible terms. $\square$ $\square$

Theorem 8 (Perfect forward secrecy). *If the ephemeral scalars are erased after use, then revealing the long-term secrets (mk_i , Cred_{ij} , or mk_{GS}) after a target session closes does not compromise that session’s key.*

Proof. A post-session reveal gives the adversary k_{lt} but not the erased scalars x, y . The key of Eq. (23) still depends on g^{xy} , which the adversary must now compute from the recorded, authenticated shares g^x, g^y —a gap-CDH instance. Because the ephemeral exchange is mandatory, there is no non-ephemeral key to fall back on. Hence past keys remain indistinguishable from uniform. $\square$ $\square$

5.7 Physical Capture Resistance

Theorem 9 (Physical capture resistance). *Capturing UAV_k and reading its NVM does not let the adversary impersonate any other UAV to the GS, nor impersonate any peer pair that does not involve k . A captured node’s peer exposure is limited to its own $N - 1$ links.*

Proof. The NVM of UAV_k holds only $\{\text{TID}_k, \mathbf{C}_k, P_k, \{\text{Cred}_{kj}\}_j\}$ plus any live session keys; all of $\text{TID}_k, \mathbf{C}_k, P_k$ are public. Impersonating UAV_m ($m \neq k$) in a fresh Phase 2 needs $K_{\text{auth}}^m = \text{KDF}(\text{mk}_m; \cdot)$; but mk_m is never stored, is not recoverable from k ’s silicon (tamper evidence), and is unpredictable (PUF assumption), so this reduces to a MAC forgery. Impersonating a pair (m, ℓ) with $k \notin \{m, \ell\}$ needs $\text{Cred}_{m\ell} = \text{KDF}(\text{mk}_{\text{GS}}; \cdot)$, which is independent of every captured Cred_{kj} (distinct KDF inputs, and mk_{GS} never leaves the GS). Only pairs that include k share a captured credential, giving the stated $N - 1$ exposure. $\square$ $\square$

5.8 Symbolic Verification

The computational theorems are corroborated by a symbolic model in the Tamarin prover [24], whose multiset-rewriting calculus expresses freshness, stateful credential issuance, and device-compromise events natively. In the model, $h, \text{MAC}, \text{AE}, \text{KDF}$ are function symbols with the usual equational theory, each PUF is a private per-device function, and helper data and all wire terms are public. The Dolev–Yao adversary controls the network; two extra rules model compromise—one that reveals a captured node’s NVM (its identities, helper data, and per-pair credentials, but neither its PUF

nor its master key) and one that reveals long-term secrets after a session closes, for the forward-secrecy query. The prover discharges lemmas that correspond one-to-one with the theorems above: injective agreement for Phase 2 and Phase 3 (Theorems 2 and 5), a no-replay lemma (Theorem 4), a capture-isolation lemma (Theorem 9), a session-key-secrecy lemma (Theorem 7), and a forward-secrecy lemma (Theorem 8). The PUF’s noise is idealised as a noiseless private function—its error tolerance is the computational correctness property of the fuzzy extractor—and confidential delivery is abstracted by a symmetric encryption operator, leaving the fine-grained secrecy argument to the computational analysis.

5.9 Summary of Security Properties

Table 3 summarises the guarantees and the mechanism behind each.

Table 3: Summary of Security Properties

Property	Result	Mechanism
UAV-GS mutual auth	Thm 2	Keyed MAC under PUF-derived mk_i
No PUF read-out oracle	Cor 3	Verify-before-respond; response stays on-device
Replay resistance	Thm 4	Nonces + timestamps + type tags
Peer mutual auth	Thm 5	Per-pair credential + keyed MAC
MITM resistance	Thm 6	Transcript-binding MACs / AEAD
Session-key secrecy	Thm 7	KDF over long-term key and DH secret
Perfect forward secrecy	Thm 8	Mandatory authenticated ephemeral DH
Physical-capture resistance	Thm 9	No stored key; per-pair credentials
Identity anonymity	—	Rotating temporary identities

6 Discussion

6.1 Scalability

Phase 2 is $O(N)$ in the swarm size and fully parallel across UAVs, since each UAV’s handshake with the GS is independent. Phase 3 is $O(N^2)$: full-mesh peer authentication runs $N(N-1)/2$ exchanges (for example 45 for $N = 10$ and 190 for $N = 20$), but these too are mutually independent and can proceed in parallel, and a deployment that only needs neighbours may authenticate a subset of pairs. Because every operation is symmetric—a hash, a MAC, an AEAD, a KDF, and one ephemeral exchange—per-message cost is small and does not grow with the swarm.

6.2 Design Choices

Three choices give the protocol its character. First, deriving a *stable* key from the PUF means the drone stores no secret and can re-authenticate any number of times from a single enrollment, rather than consuming a limited pool of challenge–response pairs. Second, rooting Phase 3 in *per-pair* credentials—rather than one swarm-wide secret—means a captured node endangers only its own links, matching the capture threat that motivates PUFs in the first place. Third, making the ephemeral exchange *mandatory* rather than optional means forward secrecy is a property of every session, not a feature that can be silently skipped.

6.3 Noise Tolerance

The BCH(255,131,18) fuzzy extractor corrects up to 18 bit-flips, comfortably above the ≈ 3.84 expected flips in a 128-bit response at a 3% error rate, so reproduction of mk_i succeeds with overwhelming probability across the temperature and voltage range of normal operation. The enrollment

is sized by Eq. (4) so that the extracted key retains full strength after the public helper data is accounted for.

6.4 Limitations and Future Work

The analysis here is at the protocol level; a mechanised end-to-end proof and a hardware prototype are natural next steps, as is an empirical study of the PUF's reliability across environmental extremes. Extending the model to dynamic swarm membership (join and leave during flight) and to mobility-induced link changes is left for future work.

7 Conclusion

We presented a four-phase PUF-based authentication protocol for UAV swarms. Its root of trust is a stable key distilled from each drone's PUF by a fuzzy extractor, so that no secret is ever stored on the device. Every handshake message is protected by a keyed MAC, and the raw PUF response never leaves the UAV, which closes the challenge-harvesting avenue that undermines naive PUF protocols. Peer authentication runs directly between UAVs, rooted in per-pair credentials delivered under authenticated encryption during the UAV-GS handshake, so a captured node compromises only its own links. Every session key folds in a mandatory, authenticated ephemeral Diffie-Hellman secret, giving perfect forward secrecy. We proved six security theorems—mutual authentication in both directions, peer authentication, replay and man-in-the-middle resistance, physical-capture resistance, session-key secrecy, and perfect forward secrecy—by reduction to standard assumptions, and mirrored them in a Tamarin symbolic model. Built from a 160-bit hash, a keyed MAC, a lightweight AEAD, a KDF, and a single elliptic curve, the protocol is well matched to the resource constraints of aerial platforms. A reference implementation and simulation study are the subject of ongoing work.

Acknowledgment

The author thanks the Indian Institute of Information Technology Guwahati for providing the research infrastructure and Dr. Rakesh Matam for his guidance.

References

- [1] A. Mukherjee, S. Bose, A. Mukherjee, and S. Saha, "Securing UAV Flying Ad Hoc Wireless Networks: Authentication Development for Robust Communications," *IEEE Access*, vol. 12, pp. 1–15, 2024.
- [2] P. Gope and B. Sikdar, "A PUF-based lightweight authentication and key agreement protocol for smart UAV networks," *IET Communications*, vol. 16, no. 18, pp. 2136–2148, 2022.
- [3] T. Bera, S. Das, and A. K. Das, "Secure and Efficient Peer2Peer Authentication-Attestation Protocol for UAV Networks," in *Proc. IEEE INFOCOM Workshop*, 2023, pp. 1–6.
- [4] National Technological University, "PUF-Based Lightweight Security Framework for Drone Networks," DR-NTU Technical Report Series, 2023.
- [5] J. Delvaux, D. Gu, I. Verbauwhede, M. Hiller, and M.-D. Yu, "Cryptographic Key Generation from PUF Data Using Efficient Fuzzy Extractors," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 2025–2038, 2020.
- [6] L. Zhang, Y. Li, Z. Wang, and C. Chen, "SRAM-PUF Key Extraction Method and Performance Analysis Based on RS and BCH Codes," *Electronics*, vol. 12, no. 4, p. 1012, 2023.
- [7] R. Maes, "Helper Data Masking for Physically Unclonable Function-Based Key Generation," *Cryptology ePrint Archive*, Report 2019/688, 2019.

- [8] U. Chatterjee, R. S. Chakraborty, and D. Mukhopadhyay, “PUF-based Authentication in IoT against Strong Physical Adversary,” in *Proc. IEEE DATE*, 2022, pp. 1–6.
- [9] B. Li, H. Zhu, J. Shen, and T. Li, “PUF-Based Secure and Efficient Anonymous Authentication Protocol for UAV Towards Cross-Domain Environments,” *IEEE Trans. Veh. Technol.*, vol. 72, no. 9, pp. 12101–12115, 2023.
- [10] A. Alkatheiri, Y. G. Alghamdi, and S. U. Jan, “Review of Physically Unclonable Functions (PUFs): Structures, Models, and Algorithms,” *Frontiers in Electronics*, vol. 4, p. 1123456, 2023.
- [11] R. Aman, K. Z. Ghafoor, and S. K. Sood, “PUF based Lightweight Authentication and Key Exchange Protocol for IoT,” in *Proc. IEEE GLOBECOM*, 2022, pp. 1–6.
- [12] S. Khan, A. Irshad, S. A. Chaudhry, and M. Alazab, “A Provably Secure and Lightweight PUF-Based Authentication Scheme for 6G-Enabled UAV Networks,” *IEEE Internet of Things J.*, vol. 11, no. 5, pp. 8532–8543, 2024.
- [13] L. Xu, X. Wang, Q. Li, and H. Wang, “An Enhanced Event-Based Dynamic Authentication Protocol Leveraging Arbiter PUF for IoT Devices,” *IEEE Internet of Things J.*, vol. 10, no. 18, pp. 16123–16135, 2023.
- [14] T. Eisenbarth *et al.*, “Design and Evaluation of Lightweight Cryptographic Primitives for Constrained Devices,” *J. Cryptographic Engineering*, vol. 12, no. 3, pp. 245–260, 2022.
- [15] A. Bogdanov, M. Knežević, G. Leander, D. Toz, K. Varici, and I. Verbauwhede, “SPONGENT: A Lightweight Hash Function,” in *Proc. CHES 2011*, Springer LNCS, vol. 6917, pp. 312–325, 2011.
- [16] National Institute of Standards and Technology (NIST), “SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions,” FIPS 202, 2015.
- [17] G. Bertoni, J. Daemen, M. Peeters, and G. Van Assche, “The Keccak Reference,” Version 3.0, 2011.
- [18] D. Dolev and A. Yao, “On the Security of Public Key Protocols,” *IEEE Trans. Inf. Theory*, vol. 29, no. 2, pp. 198–208, 1983.
- [19] Y. Dodis, R. Ostrovsky, L. Reyzin, and A. Smith, “Fuzzy Extractors: How to Generate Strong Keys from Biometrics and Other Noisy Data,” *SIAM J. Comput.*, vol. 38, no. 1, pp. 97–139, 2008.
- [20] H. Krawczyk, “Cryptographic Extraction and Key Derivation: The HKDF Scheme,” in *Advances in Cryptology — CRYPTO*, 2010, pp. 631–648.
- [21] D. J. Bernstein, “Curve25519: New Diffie–Hellman Speed Records,” in *Public Key Cryptography — PKC*, 2006, pp. 207–228.
- [22] C. Dobraunig, M. Eichlseder, F. Mendel, and M. Schl  ffer, “Ascon v1.2: Lightweight Authenticated Encryption and Hashing,” *J. Cryptology*, vol. 34, no. 3, 2021.
- [23] M. Bellare and P. Rogaway, “Entity Authentication and Key Distribution,” in *Advances in Cryptology — CRYPTO*, 1993, pp. 232–249.
- [24] S. Meier, B. Schmidt, C. Cremers, and D. Basin, “The TAMARIN Prover for the Symbolic Analysis of Security Protocols,” in *Computer Aided Verification — CAV*, 2013, pp. 696–701.